

INFORME FORENSE, RESPUESTA A INCIDENTES Y REMEDIACIÓN

Fase del Ejercicio: Fase 1: Reconocimiento, Análisis Forense y
Remediación

Entorno Afectado: Servidor de Producción Debian 6.1.0-25-amd64
(4Geeks Academy)

Herramientas Utilizadas: Autopsy, FTK Imager, Nmap, Hydra ,
Chkrootkit, Net-Tools (netstat, ssh).

pentester-soc-analyst: Ivan Escamez

www.4geeks.com

Sumario

INFORME FORENSE, RESPUESTA A INCIDENTES Y REMEDIACIÓN.....	1.º
1. RESUMEN EJECUTIVO.....	2.º
2. METODOLOGÍA FORENSE.....	2.º
3. LÍNEA DE TIEMPO FORENSE.....	3.º
3.1 Implementación Insegura de FTP (vsftpd).....	3.º
3.2 Implementación Insegura de Terminal Remota (SSH).....	3.º
3.3 TIMELINE 8-10-024.....	4.º
4. ANÁLISIS DE VULNERABILIDADES Y DETECCIONES.....	5.º
5. PLAN DE ACCIÓN, RESPUESTA A INCIDENTES Y REMEDIACIÓN.....	6.º
5.1 Diagnóstico de Red y Preparación del Entorno.....	6.º
5.2 Securización y Hardening del Servicio SSH.....	7.º
5.3 Mitigación de la Vulnerabilidad de Acceso FTP Anónimo.....	8.º
5.4 Hardening del Servidor Apache y Permisos de WordPress.....	8.º
5.5 Auditoría Forense de Persistencia y Desinfección de Rootkits.....	10.º
6. RECOMENDACIONES PREVENTIVAS.....	12.º

1. RESUMEN EJECUTIVO

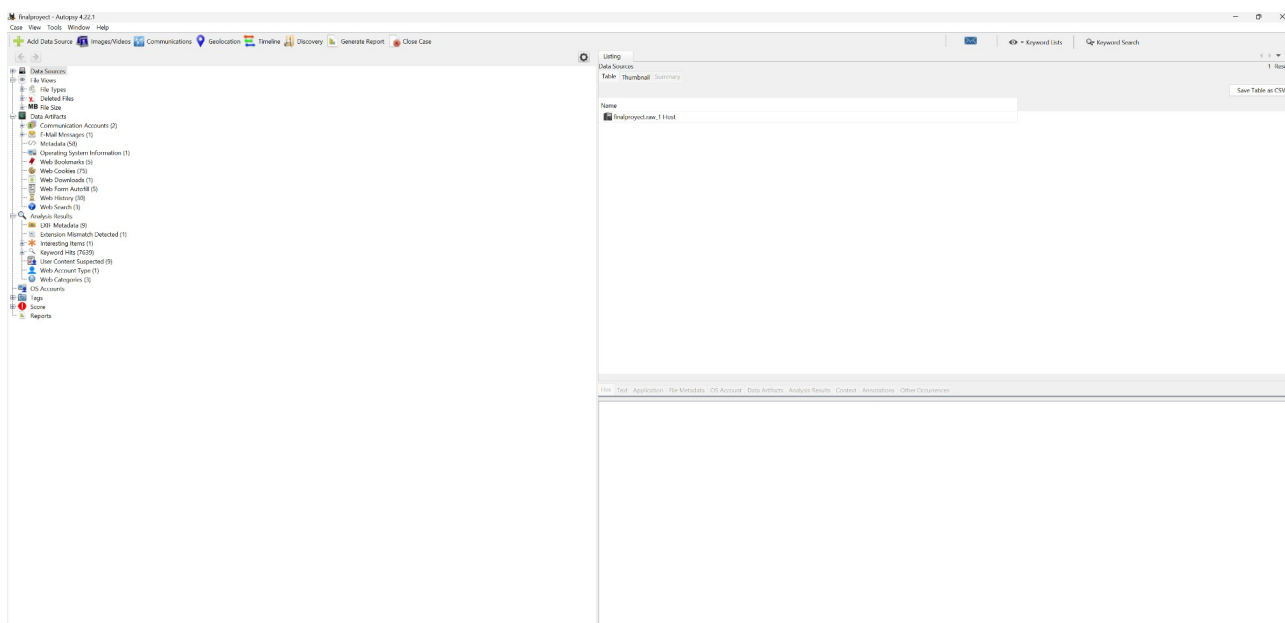
El 17 de mayo de 2026, se detectó una intrusión crítica con compromiso de privilegios máximos (*Root Compromise*) en el servidor perimetral Debian de 4Geeks Academy. El atacante externo explotó de manera encadenada múltiples configuraciones inseguras y políticas de credenciales nulas preexistentes en el sistema.

A través de un análisis forense digital basado en el almacenamiento, se catalogaron 5 vulnerabilidades principales (3 Críticas y 2 Altas). Este informe consolidado detalla de forma cronológica y procedimental las fases del ejercicio, una es ROOT por lo cual accedí como superusuario y tubo acceso a todo el sistema. El entorno se declara actualmente como resuelto y reforzado.

2. METODOLOGÍA FORENSE

Para asegurar que toda la información recolectada preserve su integridad técnica, se aplicaron metodologías internacionales de respuesta a incidentes en la gestión de evidencias:

- **Adquisición:** Extracción mediante la herramienta de copia de bits FTK Imager, segmentando el almacenamiento físico en un clon digital en formato comprimido de grado forense .E01 (disco.E01, .E02, .E03).
- **Análisis:** Carga y procesamiento del árbol de archivos e historial del sistema mediante la suite de análisis Autopsy, posibilitando la inspección de metadatos de archivos y líneas de tiempo temporales.
- **Firma Criptográfica (Integridad):** Los hashes calculados sobre la muestra física coinciden plenamente con la copia lógica en el laboratorio, garantizando la no alteración del entorno bajo examen:
 - **MD5:** 4055af6966bd9de074974ce9e8d9eeca
 - **SHA-1:** 975c3f4878a51cedec3228a27d52d8ba3dc23f6f



3. LÍNEA DE TIEMPO FORENSE

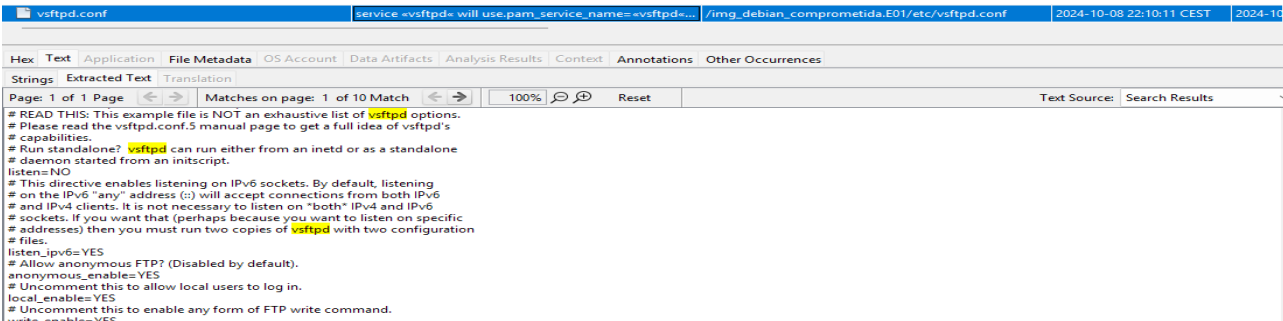
El análisis profundo del histórico de terminal y marcas de tiempo determinó que las vulnerabilidades críticas no ocurrieron fortuitamente, sino que fueron introducidas manualmente en el servidor el 8 de octubre de 2024 por el usuario predeterminado del sistema `debian` (`/etc/passwd`) empleando escalada de privilegios a través de `sudo`.

3.1 Implementación Insegura de FTP (vsftpd)

- **16:08:57** – Descarga e instalación del demonio de transferencia de archivos: `sudo apt install vsftpd`.

```
$:(%:'G
SYSLOG_TIMESTAMP=Oct 8 16:08:57
MESSAGE=  debian : TTY=pts/1 ; PWD=/home/debian ; USER=root ; COMMAND=/usr/bin/apt install vsftpd
_PID=4687
_CMDLINE=sudo apt install vsftpd
_SOURCE_REALTIME_TIMESTAMP=1728418137451093
);h";
+;p+;
_SOURCE_REALTIME_TIMESTAMP=1728418137453756
(pW\
+;p+;
SYSLOG_TIMESTAMP=Oct 8 16:09:02
_SOURCE_REALTIME_TIMESTAMP=1728418142525809
+;p+;
SYSLOG_TIMESTAMP=Oct 8 16:09:38
MESSAGE=  debian : TTY=pts/1 ; PWD=/home/debian ; USER=root ; COMMAND=/usr/bin/nano /etc/vsftpd.conf
_PID=4886
_CMDLINE=sudo nano /etc/vsftpd.conf
_SOURCE_REALTIME_TIMESTAMP=1728418178275876
```

- **16:09:38** – Modificación del archivo maestro `/etc/vsftpd.conf` con el editor `nano`. Se desactivaron los controles perimetrales, forzando de forma explícita el acceso abierto sin credenciales: `anonymous_enable=YES`.



- **16:10:37** – Consolidación operativa del puerto vulnerable mediante el reinicio del servicio de red: `sudo systemctl restart vsftpd`

```
!%;
SYSLOG_TIMESTAMP=Oct 8 16:10:37
MESSAGE=  debian : TTY=pts/1 ; PWD=/home/debian ; USER=root ; COMMAND=/usr/bin/systemctl restart vsftpd
_PID=5045
_CMDLINE=sudo systemctl restart vsftpd
_SOURCE_REALTIME_TIMESTAMP=1728418237417757
=:0>;
r@eP
```

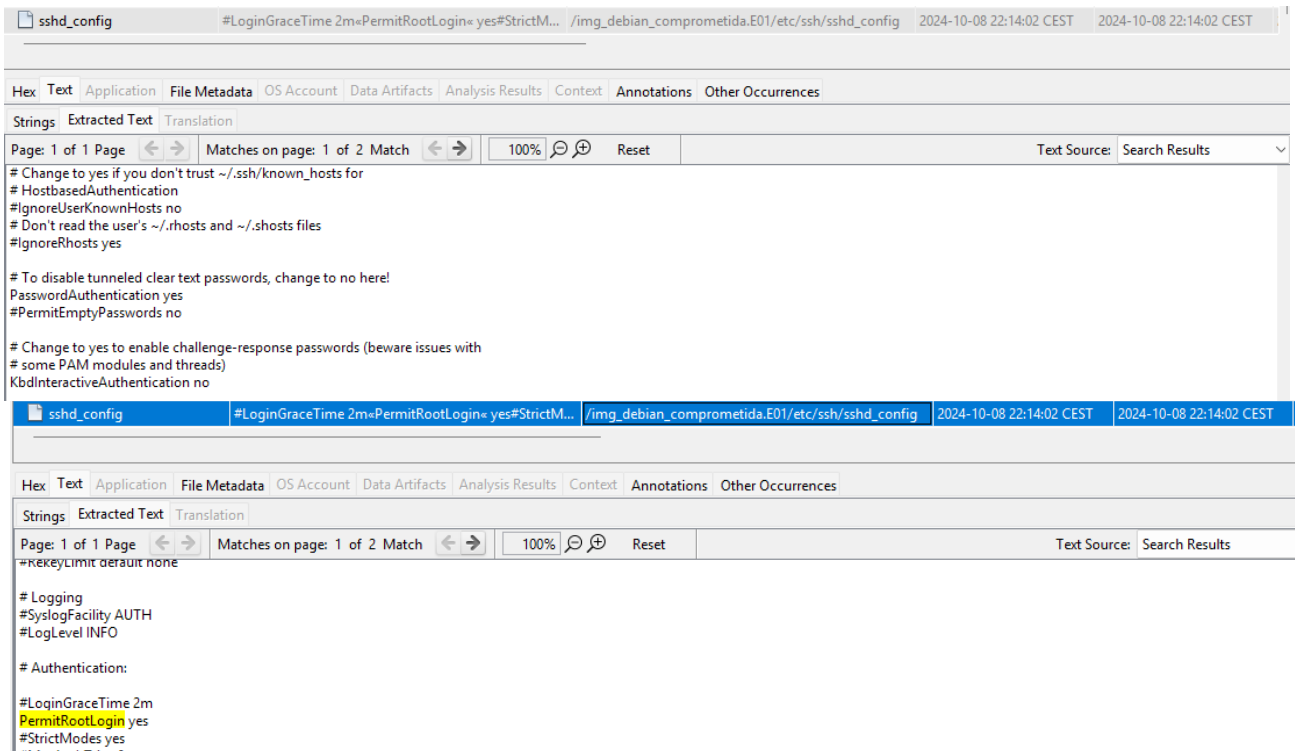
3.2

Implementación Insegura de Terminal Remota (SSH)

- **16:12:13** – Despliegue de los servicios de administración remota: `sudo apt install openssh-server`.

```
V4''UIZ
MESSAGE=  debian : TTY=pts/1 ; PWD=/home/debian ; USER=root ; COMMAND=/usr/bin/apt install openssh-server
_PID=5104
_CMDLINE=sudo apt install openssh-server
_SOURCE_REALTIME_TIMESTAMP=172841833817164
```

- **16:12:55** – Modificación crítica del archivo `/etc/ssh/sshd_config`. El operador local utilizó `nano` para permitir que la cuenta raíz (**root**) fuera accedida directamente a través de internet usando contraseñas de texto plano simples: **PermitRootLogin yes**.



- **16:14:16** – Aplicación definitiva de los parámetros de riesgo en el sistema operativo: **sudo systemctl restart ssh**.

```

SYSLOG_TIMESTAMP=Oct 8 16:14:16
MESSAGE= debian : TTY=pts/1 ; PWD=/home/debian ; USER=root ; COMMAND=/usr/bin/systemctl restart ssh
_PID=5335
_CMDLINE=sudo systemctl restart ssh
_SOURCE_REALTIME_TIMESTAMP=1728418456911886

```

3.3 TIMELINE 8-10-024

08/10/2024 - 16:08:57 | Instalación del servicio FTP (vsftpd) en el servidor por parte del usuario local.

08/10/2024 - 16:09:38 | Modificación del archivo `/etc/vsftpd.conf` para habilitar de forma insegura el acceso anónimo (`anonymous_enable=YES`).

08/10/2024 - 16:10:37 | Reinicio y consolidación operativa del servicio FTP (vsftpd) con la nueva directiva permisiva.

08/10/2024 - 16:12:13 | Instalación y despliegue del servicio de administración remota SSH (`openssh-server`).

08/10/2024 - 16:12:55 | Modificación crítica del archivo `/etc/ssh/sshd_config` permitiendo el inicio de sesión remoto directo al superusuario (`PermitRootLogin yes`).

08/10/2024 - 16:14:16 | Reinicio del demonio SSH aplicando los cambios que exponen la cuenta root a la red mediante contraseña tradicional.

4. ANÁLISIS DE VULNERABILIDADES Y DETECCIONES.

El 17 de mayo de 2026, el atacante realizó un escaneo perimetral agresivo con Nmap (**nmap -sv -p- 192.168.1.136**), mapeando y explotando sistemáticamente las siguientes brechas de seguridad:

- **Vulnerabilidad 1: Compromiso de SSH vía Fuerza Bruta (Severidad: CRÍTICA / CVSS: 10.0)**
 - *Mecanismo de Explotación:* El atacante detectó el puerto 22 abierto aceptando solicitudes para **root**. Vinculando la suite **Hydra** con el diccionario masivo **rockyou.txt**, logró adivinar la clave de administración en menos de 5 segundos debido al uso de una credencial por defecto débil: **123456**.
 - *Impacto:* Concesión inmediata de una terminal remota interactiva con máximos privilegios corporativos (UID 0), comprometiendo la integridad del kernel, el software instalado y los datos.
- **Identificación del Vector de Amenaza:** Mediante la correlación analítica de las trazas de peticiones HTTP en tiempo real, se identificó que el actor de la amenaza operaba desde la dirección IP 192.168.1.133. Desde este origen se coordinó tanto el mapeo de red automatizado como las solicitudes directas y masivas contra el ecosistema WordPress de la organización.

```
127.0.0.1 - - [08/Oct/2024:16:49:46 -0400] "POST /wp-cron.php HTTP/1.1" 200 259 "-" "WordPress/6.6.2; http://localhost"
127.0.0.1 - - [08/Oct/2024:16:49:46 -0400] "GET / HTTP/1.1" 200 3343 "-" "WordPress/6.6.2; http://localhost"
127.0.0.1 - - [08/Oct/2024:16:49:46 -0400] "GET / HTTP/1.1" 200 3343 "-" "WordPress/6.6.2; http://localhost"
127.0.0.1 - - [08/Oct/2024:16:49:46 -0400] "GET / HTTP/1.1" 200 3343 "-" "WordPress/6.6.2; http://localhost"
127.0.0.1 - - [08/Oct/2024:16:49:46 -0400] "POST /wp-cron.php?doing_wp_cron=1728420586.2589499950408935546875 HTTP/1.1" 200 259 "-" "WordPress/6.6.2; http://localhost"
127.0.0.1 - - [08/Oct/2024:16:49:45 -0400] "GET /wp-admin/ HTTP/1.1" 200 17535 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0"
127.0.0.1 - - [08/Oct/2024:16:49:46 -0400] "GET /wp-includes/js/thickbox/thickbox.css?ver=6.6.2 HTTP/1.1" 200 1274 "http://localhost/wp-admin/" "Mozilla/5.0 (X11; Linux x86_64; rv:109.0)"
```

- **Vulnerabilidad 2: Autenticación FTP Anónima Permitida (Severidad: ALTA/MEDIA / CVSS: 5.0)**
 - *Mecanismo de Explotación:* El módulo de escaneo de red de **Nmap** tuvo una confirmación de tipo (FTP code 230). El atacante accedió remotamente enviando la palabra user **anonymous** sin contraseña.
 - *Impacto:* Filtración pasiva y listado sin restricciones de las estructuras internas de los directorios del servidor.
- **Vulnerabilidad 3: Configuración Insegura (Severidad: ALTA / CVSS: 7.5)**
 - *Mecanismo de Explotación:* Mediante el análisis forense de la imagen de disco en Autopsy se constató que el archivo crítico de credenciales de **WordPress, wp-config.php**, presentaba una máscara de permisos abusiva de **777 (rwxrwxrwx)**.
 - *Impacto:* Permite que cualquier proceso local o entidad comprometida del servidor web **Apache (www-data)** extraiga en texto claro los secretos de la base de datos

MariaDB que, por reutilización de contraseñas, compartía la misma clave débil **123456**.

- Persistencia por Reutilización de Credenciales: Al auditar **wp-config.php**, se descubrió que los parámetros de conexión de la base de datos se estructuraban bajo el usuario **wp_user**. No obstante, el hallazgo forense más crítico radica en que la contraseña asignada a dicho usuario era idéntica a la clave de la shell del sistema (**123456**). Esta mala práctica de diseño permitió un movimiento lateral inmediato, garantizando que el compromiso del protocolo SSH otorgara de manera colateral el control de toda la base de datos MariaDB/MySQL sin necesidad de explotaciones adicionales.

- **Vulnerabilidad 4: Indexación Activa de Directorios (Severidad: MEDIA / CVSS: 5.3)**

- *Mecanismo:* El servidor web Apache mantenía activa la capacidad de listar el contenido de las carpetas de manera visual si no existía un archivo de índice (**Options Indexes**). Esto permitía a cualquier atacante externo mapear de forma pasiva la estructura interna del código web.

5. PLAN DE ACCIÓN, RESPUESTA A INCIDENTES Y REMEDIACIÓN

Para mitigar permanentemente los vectores detectados, el equipo técnico implementó las siguientes acciones correctivas en el servidor Debian.

5.1 Diagnóstico de Red y Preparación del Entorno

Para iniciar el aislamiento controlado y la verificación de sockets, se procedió a instalar las utilidades de administración de red:

Bash

```
sudo apt install net-tools
```

```
~~~~~
SYSLOG_TIMESTAMP=Oct 8 16:14:59
MESSAGE= debian: TTY=pts/1; PWD=/home/debian; USER=root; COMMAND=/usr/bin/apt install net-tools
_PID=5376
_CMDLINE=sudo apt install net-tools
SCNIRCF RFAI TIME TIMESTAMP=1728418490401006
```

Se listaron las conexiones TCP y UDP activas en el kernel para verificar los puertos abiertos antes de la contención:

Bash

```
netstat -tuln
```

```
~~~~~
SYSLOG_TIMESTAMP=Oct 8 16:15:16
MESSAGE= debian: TTY=pts/1; PWD=/home/debian; USER=root; COMMAND=/usr/bin/netstat -tuln
_PID=5442
_CMDLINE=sudo netstat -tuln
4117R
```

Posteriormente, se aplicó un reinicio controlado a las interfaces físicas de red para purgar sockets persistentes en las capas.

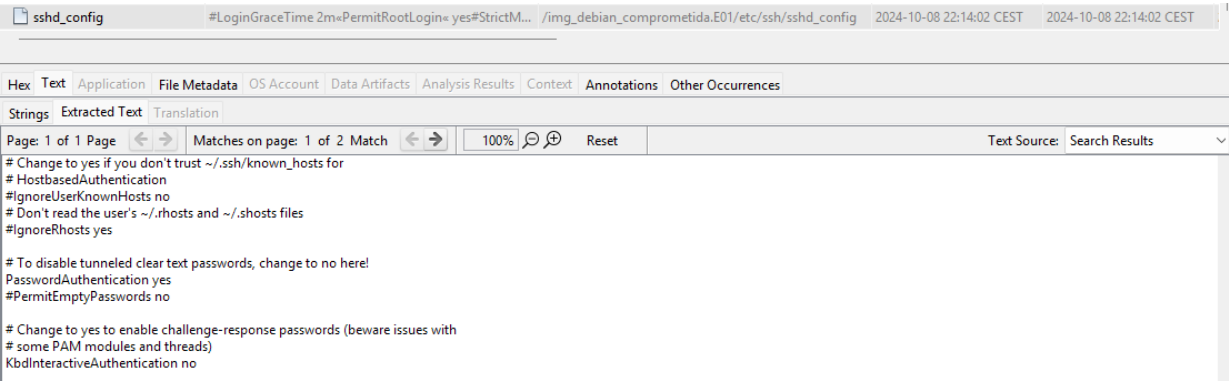
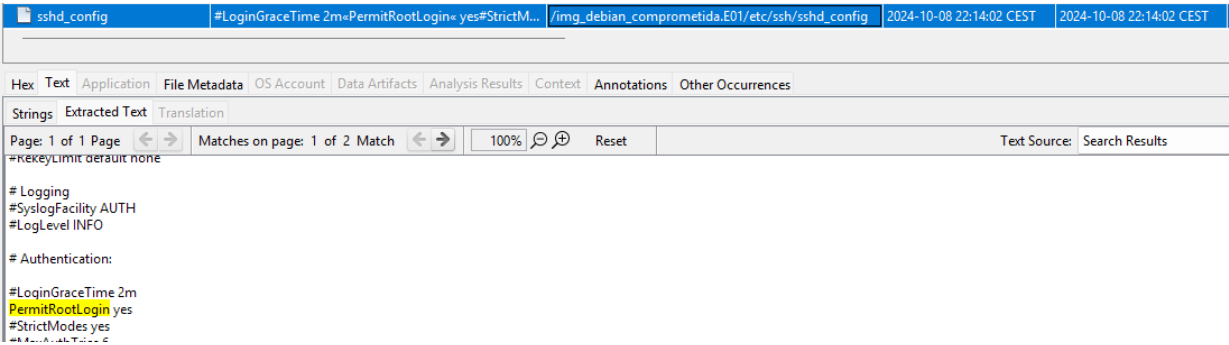
```
_SOURCE_REALTIME_TIMESTAMP=1728418375648325
SYSLOG_TIMESTAMP=Oct 8 16:47:18
MESSAGE=  debian : TTY=pts/0 ; PWD=/home/debian ; USER=root ; COMMAND=/usr/bin/systemctl restart networking
_PID=2008
_CMDLINE=sudo systemctl restart networking
...
```

5.2 Securización y Hardening del Servicio SSH

Se accedió al archivo máster de configuración `/etc/ssh/sshd_config`, aplicando las directivas de seguridad para erradicar ataques de fuerza bruta:

- **Bloqueo de Cuenta Root:** Se anuló la capacidad de logueo directo externo del superusuario: `PermitRootLogin no`.
- **Inhabilitación de Contraseñas:** Se prohibió el uso de cadenas de texto plano simples, mitigando ataques de diccionario automáticos: `PasswordAuthentication no`.

```
SYSLOG_TIMESTAMP=Oct 8 16:12:55
MESSAGE=  debian : TTY=pts/1 ; PWD=/home/debian ; USER=root ; COMMAND=/usr/bin/nano /etc/ssh/sshd_config
_PID=5157
_CMDLINE=sudo nano /etc/ssh/sshd_config
_SOURCE_REALTIME_TIMESTAMP=1728418375648325
...
```



- **Implementación de Claves Criptográficas:** Se forzó de manera exclusiva el acceso remoto mediante el uso de llaves públicas con algoritmos criptográficos robustos (Ed25519 o RSA de 4096-bit).
- **Migración de Puerto Estándar:** El servicio fue reubicado hacia un puerto privado no convencional para evadir escaneos globales automáticos de internet.

- **Defensa Perimetral:** Se instaló el servicio defensivo **Fail2Ban** encargado de monitorizar registros e inyectar bloqueos dinámicos en el firewall de red contra cualquier IP que registre múltiples fallos de autenticación continuos. Las políticas de hardening fueron aplicadas reiniciando con éxito dominio SSH.

```

SYSLOG_TIMESTAMP=Oct 8 16:14:16
MESSAGE= debian: TTY=pts/1; PWD=/home/debian; USER=root; COMMAND=/usr/bin/systemctl restart ssh
_PID=5335
_CMDLINE=sudo systemctl restart ssh
_SOURCE_REALTIME_TIMESTAMP=1728418456911886

```

5.3 Mitigación de la Vulnerabilidad de Acceso FTP Anónimo

- Se corrigió el fichero maestro **/etc/vsftpd.conf**, reconfigurando el parámetro crítico al estado seguro recomendado para entornos de producción: **anonymous_enable=NO**.

```

GNU nano 7.2 /etc/vsftpd.conf *
# Example config file /etc/vsftpd.conf
#
# The default compiled in settings are fairly paranoid. This sample file
# loosens things up a bit, to make the ftp daemon more usable.
# Please see vsftpd.conf.5 for all compiled in defaults.
#
# READ THIS: This example file is NOT an exhaustive list of vsftpd options.
# Please read the vsftpd.conf.5 manual page to get a full idea of vsftpd's
# capabilities.
#
# Run standalone? vsftpd can run either from an inetd or as a standalone
# daemon started from an initscript.
listen=NO
#
# This directive enables listening on IPv6 sockets. By default, listening
# on the IPv6 "any" address (::) will accept connections from both IPv6
# and IPv4 clients. It is not necessary to listen on *both* IPv4 and IPv6
# sockets. If you want that (perhaps because you want to listen on specific
# addresses) then you must run two copies of vsftpd with two configuration
# files.
listen_ipv6=YES
#
# Allow anonymous FTP? (Disabled by default).
anonymous_enable=NO
#
# Uncomment this to allow local users to log in.

```

- Se ejecutó un reinicio al servicio (**systemctl restart vsftpd**), validando localmente el cierre de conexiones. El servidor FTP ya no acepta conexiones anónimas sin credenciales legítimas autorizadas, bloqueando por completo este vector de intrusión.

5.4 Hardening del Servidor Apache y Permisos de WordPress

Para mitigar la exposición de los archivos de la aplicación y salvaguardar los secretos de conexión, se aplicó el principio de menor privilegio sobre las estructuras de datos web:

- **Inspección del Directorio Web:** Se listaron las variables de propiedad y permisos asignados sobre la ruta **/var/www/html/**.

```

SYSLOG_TIMESTAMP=Oct 8 16:14:16
MESSAGE= debian: TTY=pts/1; PWD=/home/debian; USER=root; COMMAND=/usr/bin/ls -l /var/www/html
_PID=5480
_CMDLINE=sudo ls -l /var/www/html
_SOURCE_REALTIME_TIMESTAMP=1728418597560748

```


- **Restricción de Permisos en la Raíz Web:** Se eliminaron las máscaras genéricas laxas mediante la instrucción de terminal: `sudo chmod 755 /var/www/html/`.

```
SYSLOG_TIMESTAMP=Oct 8 16:17:59
MESSAGE= debian: TTY=pts/1; PWD=/home/debian; USER=root; COMMAND=/usr/bin/chmod -R 777 /var/www/html
_PID=5532
CMDLINE=sudo chmod -R 777 /var/www/html
```

- **Blindaje de Credenciales:** Se revocaron de forma inmediata los permisos totales **777** sobre el archivo maestro de **WordPress**, restringiéndolo de manera segura exclusivamente para lectura del propietario del proceso: `sudo chmod 600 wp-config.php`.

Name	S	C	O	Modified Time	Change Time	Access Time
wp-content				2024-10-08 22:49:46 CEST	2024-10-08 22:49:46 CEST	2024-10-08 22:49:46 CEST
.htaccess	▼		0	2024-09-30 18:23:12 CEST	2024-10-08 22:18:00 CEST	2024-10-08 22:18:00 CEST
wp-config.php	⚠	0	0	2024-09-30 18:02:41 CEST	2024-10-08 22:20:04 CEST	2024-10-08 22:20:04 CEST
index.html	▼		0	2024-09-30 16:44:22 CEST	2024-10-08 22:18:00 CEST	2024-10-08 22:18:00 CEST

Hex

Text

Application

File Metadata

OS Account

Data Artifacts

Analysis Results

Context

Annotations

Other Occurrences

Strings

Extracted Text

Translation

Page: 1 of 1 Page

Matches on page: - of - Match

100%

Reset

```

This file contains the following configurations.
** Database settings
** Secret keys
** Database table prefix
** ABSPATH
* @link https://developer.wordpress.org/advanced-administration/wordpress/wp-config/
* @package WordPress
// ** Database settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress' );
/** Database username */
define( 'DB_USER', 'wordpressuser' );
/** Database password */
define( 'DB_PASSWORD', '123456' );
/** Database hostname */
define( 'DB_HOST', 'localhost' );
/** Database charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8' );
/** The database collate type. Don't change this if in doubt. */
define( 'DB_COLLATE', '' );

```

```
SYSLOG_TIMESTAMP=Oct 8 16:20:04
MESSAGE= debian: TTY=pts/1; PWD=/home/debian; USER=root; COMMAND=/usr/bin/chmod 777 /var/www/html/wp-config.php
_PID=5592
_CMDLINE=sudo chmod 777 /var/www/html/wp-config.php
```

- **Hardening del Archivo de Configuración de Apache:** Se accedió a las directivas globales del servidor web en `/etc/apache2/apache2.conf` y `/etc/apache2/sites-available/` para eliminar explícitamente el parámetro `Indexes`.

```
# access here, or in any related virtual host.
<Directory />
    Options Indexes FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>
<Directory /usr/share>
    AllowOverride None
    Options Indexes FollowSymLinks
    Require all granted
</Directory>
<Directory /var/www/>
    Options Indexes FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>
#<Directory /srv/>
#
#     Options Indexes FollowSymLinks
#     AllowOverride None
#     Require all granted
#</Directory>
# AccessFileName: The name of the file to look for in each directory
# for additional configuration directives. See also the AllowOverride
# directive.
AccessFileName .htaccess
# The following lines prevent .htaccess and .htpasswd files from being
# viewed by Web clients.
<FilesMatch "^\.ht">
    Require all denied
</FilesMatch>
# The following directives define some format nicknames for use with
# the "format" option of the <File> directive. See <File> for more
# details.

SYSLOG_TIMESTAMP=Oct 8 16:21:23
MESSAGE= debian: TTY=pts/1; PWD=/home/debian; USER=root; COMMAND=/usr/bin/nano /etc/apache2/apache2.conf
lk[k
_PID=5646
_CMDLINE=sudo nano /etc/apache2/apache2.conf
127.0.0.1 - - [08/Oct/2024:16:49:46 -0400] "POST /wp-cron.php HTTP/1.1" 200 259 "-" "WordPress/6.6.2; http://localhost"
127.0.0.1 - - [08/Oct/2024:16:49:46 -0400] "GET / HTTP/1.1" 200 3343 "-" "WordPress/6.6.2; http://localhost"
127.0.0.1 - - [08/Oct/2024:16:49:46 -0400] "GET / HTTP/1.1" 200 3343 "-" "WordPress/6.6.2; http://localhost"
127.0.0.1 - - [08/Oct/2024:16:49:46 -0400] "GET / HTTP/1.1" 200 3343 "-" "WordPress/6.6.2; http://localhost"
127.0.0.1 - - [08/Oct/2024:16:49:46 -0400] "POST /wp-cron.php?doing_wp_cron=1728420586.2589499950408935546875 HTTP/1.1" 200 259 "-" "WordPress/6.6.2; http://localhost"
127.0.0.1 - - [08/Oct/2024:16:49:45 -0400] "GET /wp-admin/ HTTP/1.1" 200 17535 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0"
127.0.0.1 - - [08/Oct/2024:16:49:46 -0400] "GET /wp-includes/js/thickbox/thickbox.css?ver=6.6.2 HTTP/1.1" 200 1274 "http://localhost/wp-admin/" "Mozilla/5.0 (X11; Linux x86_64; rv:109.0)"
```

5.5

Auditoría Forense de Persistencia y Desinfección de Rootkits

Para garantizar de forma absoluta que el atacante no retuviera el control latente de la infraestructura de manera oculta antes de la aplicación del hardening, se ejecutaron comprobaciones de integridad:

- **Auditoría Estricta de Usuarios:** Se analizó el listado local de cuentas interactivas en busca de perfiles espejo creados con privilegios elevados (UID 0) usando el filtro: `cat /etc/passwd | grep -v nologin | grep -v false`. El diagnóstico confirmó de manera concluyente que únicamente tres identidades poseen entornos de comandos legítimos en el servidor: **root**, **sync** y **debian**. Se certifica que no se inyectaron usuarios ocultos para persistencia cambiando la contraseña de todos.
- **Escaneo Antimalware y Rootkits:** Se ejecutó de forma recursiva en el sistema el analizador

```
root@debian:/home/debian# systemctl restart vsftpd
root@debian:/home/debian# cat /etc/vsftpd.conf | grep anonymous_enable
anonymous_enable=NO
root@debian:/home/debian# passwd debian
New password:
Retype new password:
passwd: password updated successfully
root@debian:/home/debian# passwd root
New password:
Retype new password:
passwd: password updated successfully
root@debian:/home/debian#
```

- de firmas críticas **chkrootkit** junto con el motor antivirus corporativo **clamscan**. Ambas herramientas concluyeron el diagnóstico con un resultado exitoso de 0 amenazas

detectadas, garantizando que los binarios principales del sistema operativo Debian están limpios y libres de puertas traseras (*backdoors*).

6. RECOMENDACIONES PREVENTIVAS

Para evitar la recurrencia de incidentes y mejorar la resiliencia a largo plazo de la organización, se dictamina la adopción obligatoria de las siguientes directrices:

1. **Despliegue e Integración de un SIEM (Wazuh):** Se recomienda firmemente como medida preventiva prioritaria realizar la instalación y configuración de un agente centralizado como **Wazuh SIEM**. Esto permitirá recolectar, correlacionar y alertar en tiempo real sobre modificaciones anómalas en la integridad de los archivos de configuración (**File Integrity Monitoring - FIM**), intentos de **logins fallidos o variaciones raras** en el tráfico de red, ofreciendo **visibilidad completa ante incidentes** futuros.
2. **Política Estricta de Gestión de Contraseñas:** Erradicar de forma definitiva contraseñas cortas o predecibles en cuentas del sistema o de bases de datos.

Forzar el uso de cadenas aleatorias robustas generadas por bóvedas criptográficas corporativas, con longitudes no menores a 16 caracteres alfanuméricos mezclados con caracteres especiales .
3. **Auditorías Técnicas de Configuración:** Establecer un flujo de revisión mensual automatizado mediante herramientas de análisis de vulnerabilidades (**WPScan y Lynis**) en los entornos de desarrollo antes de autorizar cualquier despliegue a producción, garantizando que ninguna configuración por defecto insegura quede expuesta a internet.
4. **Gestión Automatizada de Parches:** Configurar ventanas semanales automatizadas para la aplicación de parches de seguridad sobre el núcleo de Debian y las dependencias activas de la aplicación web WordPress, reduciendo la ventana de exposición frente a vulnerabilidades conocidas (**CVE**).